PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité Windows 10 par virtualisation

03-530 ANSSI - Fonctionnalités de sécurité de Windows 10 reposant sur la virtualisation — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le VSM isole les processus critiques du système d'exploitation traditionnel grâce à un hyperviseur.
2. Device Guard combine l'intégrité du code protégée par l'hyperviseur (HVCI) et l'intégrité du code configurable (CCI).
3. Credential Guard protège les secrets d'authentification en les isolant dans le Trustlet LSAIso.exe.

La sécurité reposant sur la virtualisation

Notion	À retenir
Fonctionnement VSM	**VBS** réservée aux éditions **Entreprise** et **Éducation**. Utilise **Intel-VT**, **AMD-V** et **SLAT** pour isoler l'OS via un hyperviseur, un micro-noyau **SKM** et un environnement **IUM** pour les **Trustlets** (signés, dialogue par **appel de procédure distante**).
Limites et UEFI	Si la **chaîne de démarrage** est compromise, l'hyperviseur l'est aussi. Il faut protéger l'**UEFI** (mot de passe) et maintenir ses logiciels. Le **démarrage sécurisé** est un prérequis fondamental.
Activation VBS	L'hyperviseur impose des permissions écriture/exécution **exclusives** sur la mémoire du noyau et détecte les rootkits (**Hyper Guard**) : activer la VBS sur tout poste compatible, même sans Trustlet. Sécurité réduite sans **démarrage sécurisé** ou **protections DMA**. Attention aux **solutions de virtualisation tierces**.

Device Guard et intégrité du code

Notion	À retenir
Mécanismes d'intégrité	Valide la **signature cryptographique** (pilotes, binaires, scripts, paquets) via **KMCI** (noyau) et **UMCI** (utilisateur).
Stratégie CCI	Combinaison configurable de **KMCI** et **UMCI** (plus fine qu'**Applocker**). Mode **enforced** recommandé sur les **postes sensibles** ; extension aux autres postes à envisager, éventuellement précédée du mode **audit** (non bloquant). Fichier de stratégie : droits d'écriture restreints, **signé**.
Protection hyperviseur	**HVCI** déporte la vérification dans un **Trustlet** protégé par le **VSM**. Nécessite compatibilité pilotes et verrouillage **UEFI**.

Synthèse de Credential Guard

Notion	À retenir
Principes techniques	Déporte le traitement vers le Trustlet isolé `LSAIso.exe` pour contrer **Pass-the-Hash** et **Pass-the-Ticket** ; `LSASS.exe` ne garde que des **blobs chiffrés et éphémères**.
Périmètre de mise en œuvre	Recommandé sur les **postes de travail sensibles** (comptes **Active Directory**, **Tiers 0**, éventuellement **Tiers 1**) pour limiter le **déplacement latéral** et l'**élévation de privilèges**.
Limites et mesures	Ne protège pas les **comptes locaux**, les programmes hors `LSASS.exe`, les **enregistreurs de frappe** ou **attaques physiques**. Nécessite : **verrouillage UEFI**, gestion des mots de passe admins locaux et sécurité physique.

Pièges et confusions

- ⚠ Croire que Credential Guard permet de se passer d'une gestion sécurisée des comptes à privilèges.
- ⚠ Négliger la protection du fichier de stratégie CCI : une modification malveillante peut causer un déni de service empêchant les systèmes de démarrer.
- ⚠ Utiliser l'option HvciOptions en mode Strict, ce qui est déconseillé et peut empêcher le démarrage.
- ⚠ Penser que Credential Guard protège les comptes locaux ou les programmes hors LSASS.exe.

Sigles et définitions

VBS	Ensemble des fonctionnalités de sécurité de Windows 10 reposant sur la virtualisation.
VSM	Environnement virtualisé de Microsoft, isolé du système d'exploitation traditionnel par un hyperviseur.
Trustlet	Processus de confiance s'exécutant dans le VSM, uniquement édité par Microsoft.
Device Guard	Ensemble formé par l'intégrité du code protégée par l'hyperviseur (HVCI) et l'intégrité du code configurable (CCI).
Credential Guard	Fonctionnalité isolant dans un Trustlet dédié, LSAIso.exe, les secrets d'authentification.
Pass-the-Hash	Technique d'attaque consistant à réutiliser un condensat NTLM extrait de la mémoire pour s'authentifier.
Pass-the-Ticket	Technique d'attaque consistant à réutiliser un ticket Kerberos extrait de la mémoire pour s'authentifier.

Auto-test

1. À quelles éditions de Windows 10 la VBS est-elle réservée ?
2. Quel processus est utilisé par Credential Guard pour isoler les secrets d'authentification ?
3. Comment communique un Trustlet avec le système standard ?
4. Sur quels postes le mode enforced de la stratégie CCI est-il recommandé, et quel mode peut précéder son extension ?
5. Que contient le processus LSASS.exe après l'activation de Credential Guard ?

Réponses : **1.** Entreprise et Éducation · **2.** LSAIso.exe · **3.** Par appel de procédure distante · **4.** Sur les postes de travail sensibles ; le mode audit, non bloquant · **5.** Des blobs chiffrés et éphémères

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.